

Technical Analysis of Microsoft Exchange ProxyLogon

DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING
23CSE313 – Foundations of Cyber Security

TEAM MEMBERS

KAUSHAL LOYA
CB.SC.U4CSE23627

PAARTHU REDDY
CB.SC.U4CSE23639

PRIYANSH NARANG
CB.SC.U4CSE23642

Contents

1	Introduction	3
2	Incident Type & Entry Point	3
2.1	Technical Execution of Entry	3
2.2	MITRE ATTACK Mapping	3
2.3	Key Technical Indicators	4
3	Root Cause Analysis	4
3.1	CWE and Technical Flaws	4
3.2	Step-by-Step Exploitation (CAPEC-522)	4
4	Detection Strategy	5
4.1	Log Analysis	5
4.2	Behavioral Artifacts	5
5	Prevention / Mitigation Strategy	5
5.1	Countermeasures (MITRE DEFEND)	5
5.2	Operational Hardening	5
6	Real-World Relevance	6
7	Conclusion	6
8	References	6

1 Introduction

The ProxyLogon incident represents one of the most significant security events in recent enterprise history, centered on a chain of vulnerabilities in Microsoft Exchange Server (versions 2013, 2016, and 2019). Discovered in early 2021, the primary flaw, CVE-2021-26855, allowed unauthenticated attackers to perform Remote Code Execution (RCE) on servers exposed to the internet.

This attack bypassed traditional authentication perimeters, allowing threat actors to read private emails and deploy persistent backdoors called web shells. Globally, over 250,000 organizations were impacted, ranging from small businesses to high-level government agencies. This report utilizes a multi-framework approach—mapping technical details to CVE, CWE, CAPEC, ATTACK, and DEFEND—to provide a comprehensive root cause and mitigation analysis.

2 Incident Type & Entry Point

ProxyLogon is technically classified as a Server-Side Request Forgery (SSRF) vulnerability. The attack targets the Exchange Control Panel (ECP) virtual directory, typically accessible via HTTPS port 443.

2.1 Technical Execution of Entry

- **Initial Request:** Attackers initiate the exploit by sending unauthenticated POST requests to static files, specifically `/ecp/{version}/proxyLogon.ecp`.
- **Request Forgery:** By manipulating the request, the attacker forces the Exchange server to authenticate to its own backend services using its SYSTEM-level privileges.
- **Chaining for RCE:** While the SSRF provides the “foot in the door,” it is chained with CVE-2021-27065, an arbitrary file write flaw, to achieve full system compromise.

2.2 MITRE ATTACK Mapping

Phase	ID	Technique	Details & Application in Incident
Reconnaissance	T1595	Active Scanning	Attackers scan for internet-exposed Exchange servers to leak the backend FQDN via unauthenticated RPC/HTTP headers.
Initial Access	T1190	Exploit Public-Facing Application	Execution of an SSRF vulnerability on the Exchange Control Panel (ECP) to bypass authentication.

Execution	T1203	Exploitation for Client Execution	Chaining the initial SSRF with CVE-2021-27065 to achieve arbitrary file write and remote code execution.
Persistence	T1505.003	Web Shell	Deployment of malicious ASPX files (e.g., shell.aspx) in accessible web directories to maintain access.
Privilege Escalation	T1550	Alternate Authentication Material	Exploiting leaked SIDs to impersonate administrative users.
Exfiltration	T1041	Exfiltration Over C2 Channel	Theft of sensitive email data following server compromise.

2.3 Key Technical Indicators

- Primary Target: Exchange Control Panel (ECP) virtual directory over HTTPS port 443.
- Impacted Versions: Microsoft Exchange Server 2013, 2016, and 2019.
- Severity: CVSS v3.1 base score of 9.1 (Critical).

3 Root Cause Analysis

The root cause of ProxyLogon lies in improper input validation within the Exchange Backend Integration (EBI) module. This failure in sanitizing URLs within the proxy logic allows the SSRF to occur.

3.1 CWE and Technical Flaws

CWE ID	Weakness Name	Technical Flaw & Role in ProxyLogon
CWE-918	Server-Side Request Forgery	Improper input validation allowed forged requests to internal services.
CWE-200	Exposure of Sensitive Information	Used to leak backend hostnames and user SIDs from error responses.
CWE-20	Improper Input Validation	Insufficient URL sanitization allowed manipulation of X-BEResource cookie.
CWE-502	Deserialization of Untrusted Data	Utilized during RCE stage after malicious file upload.
CWE-434	Unrestricted File Upload	Attackers upload malicious ASPX web shells.

3.2 Step-by-Step Exploitation (CAPEC-522)

Following CAPEC-522 (Request Forgery via forged SSRF), the attack follows this lifecycle:

1. Backend Reconnaissance: Attackers leak the internal FQDN via requests to `/rpc/rpcproxy.dll`.
2. Admin DN Extraction: Manipulated X-BEResource cookie to find admin LegacyDN.
3. SID Identification: Server error responses reveal the target user's SID.
4. Session Establishment: Using SID to impersonate administrator.
5. Payload Delivery: Upload ASPX web shell via CVE-2021-27065.

4 Detection Strategy

Detection relies on identifying both the SSRF footprint and web shell artifacts.

4.1 Log Analysis

- IIS Log Monitoring: Look for POST requests to `/ecp` directories with X-BEResource cookies without valid login.
- Anomalous Headers: Requests directed at `localhost:443` or internal MAPI ports.

4.2 Behavioral Artifacts

- Presence of unexpected `.aspx` files in `C:\inetpub\wwwroot`.
- YARA scanning for web shells like `diagUtility.svc`.
- EDR monitoring mapped to ATT&CK techniques.

5 Prevention / Mitigation Strategy

A defense-in-depth approach is required.

5.1 Countermeasures (MITRE DEFEND)

- D3-PBA: Implement WAF rules to block SSRF patterns.
- D3-ENC: TLS inspection to inspect encrypted traffic.

5.2 Operational Hardening

- Immediate patching (KB5000871+).
- Zero-Trust Architecture with MFA.
- Network segmentation restricting port 443.
- Least privilege service accounts.

6 Real-World Relevance

ProxyLogon demonstrated the risks of unpatched enterprise software.

- Initially exploited by Hafnium (China-linked APT).
- Later weaponized by ransomware groups like DearCry and cryptominers such as LemonDuck.
- Impact across government, finance, and healthcare sectors.
- Triggered emergency patching mandates by CISA.

7 Conclusion

The ProxyLogon incident highlights the critical necessity of strong vulnerability management and layered defense architectures. Zero-day vulnerabilities (CVE-2021-26855, CVE-2021-26857, CVE-2021-26858, and CVE-2021-27065) demonstrated how SSRF could be chained with other flaws to achieve unauthenticated RCE.

Organizations must move beyond reactive patching toward proactive security strategies supported by frameworks like MITRE ATT&CK and MITRE D3FEND.

Timely patching, continuous monitoring, and threat intelligence integration remain the most effective defense mechanisms against such large-scale cyber threats.

8 References

- Praetorian – Reproducing the Microsoft Exchange ProxyLogon Exploit Chain
- Cyberpolygon – Hunting Down MS Exchange Attacks
- ReliaQuest – The Microsoft Exchange Server Exploit
- ProxyLogon.com – ProxyLogon Official Site
- MITRE Repositories: CVE, CWE, CAPEC, ATT&CK, D3FEND